

Matriz de Evaluación PRAGMATIC de Métricas PASTA+STRIDE

Escala 1-5 para cada criterio (1 = muy bajo, 5 = muy alto)

Leyenda PRAGMATIC:[web:50][web:52][web:58]

P = Predictiva, R = Relevante, A = Accionable, G = Genuina, M = Significativa (Meaningful),
C = Precisa (accurate), T = Oportuna (Timely), I = Independiente, \$ = Rentable (Cheap).

Nota: los valores propuestos son orientativos para el contexto nacional español; deben ajustarse según calidad de datos, obligaciones de reporte y capacidades institucionales.[web:21][web:53][web:56]

1. Métricas del Indicador 1 - Cobertura de Threat Modeling

M1.1 - % de OSE/entidades NIS2 con Threat Modeling en sistemas críticos

- Descripción: porcentaje de operadores de servicios esenciales y entidades NIS2 que declaran utilizar al menos una metodología formal de modelado de amenazas en sus sistemas críticos.
- Fuente: encuestas nacionales, auditorías, informes sectoriales.[web:8][web:21][web:31]

Criterio	Puntuación (1-5)	Comentario breve
P	4	Un aumento suele anticipar mejor gestión de riesgos y reducción futura de incidentes graves.
R	5	Directamente alineada con objetivos nacionales de madurez y resiliencia (G1, G2).
A	4	Permite orientar políticas públicas (incentivos, sanciones, apoyo) y priorizar sectores rezagados.
G	3	Depende de auto-declaración; puede haber maquillaje corporativo.
M	5	Fácil de interpretar: porcentaje de tejido crítico que “juega en la liga correcta”.
C	3	Precisión condicionada por el rigor de las encuestas/auditorías.
T	4	Actualizable anualmente; cambios se observan en 1-2 años.
I	3	Puede estar influenciada por modas o cambios de reporting, no sólo por realidad técnica.
\$	4	Recogida relativamente barata mediante cuestionarios estructurados y muestreos.

M1.2 – % de OSE con revisión anual de modelos de amenazas

Criterio	Puntuación	Comentario
P	4	Captura la “vitalidad” del proceso; revisar más predice mejor adaptación.
R	4	Relevante para medir madurez procedimental y no sólo adopción nominal.
A	4	Permite exigir ciclos mínimos de revisión en regulación/guías.
G	3	Riesgo de confundir revisiones formales con revisiones sustantivas.
M	4	Diferencia organizaciones que “tienen modelo” de las que “lo usan”.
C	3	Precisión limitada por la definición de “revisión”.
T	4	Datos anuales razonables para seguimiento.
I	3	Ligera dependencia de cultura de reporte.
\$	4	Similar coste a M1.1.

M1.3 – % de proyectos críticos con Threat Modeling en fase de diseño

Criterio	Puntuación	Comentario
P	5	Muy predictiva de reducción de defectos e incidentes futuros.
R	5	Toca el corazón de “shift-left” y DevSecOps.
A	4	Permite orientar guías de contratación y desarrollo público/privado.
G	3	Difícil de verificar sin auditoría o muestreo técnico.
M	5	Mensaje claro: “diseñamos con amenazas en mente”.
C	3	Requiere definiciones claras de “proyecto crítico” y “Threat Modeling”.
T	3	No siempre sencillo obtener datos en tiempo adecuado.
I	3	Puede verse afectada por estrategias de cumplimiento formalista.
\$	3	Algo más cara: exige recabar información a nivel de proyecto.

2. Métricas del Indicador 2 – STRIDE agregado

M2.1.x – N° de incidentes significativos por categoría STRIDE por año (normalizado)

Criterio	Puntuación	Comentario
P	5	Tendencias por categoría STRIDE son muy valiosas para anticipar prioridades de defensa.
R	5	Directamente alineada con protección de servicios esenciales (G1).
A	4	Permite ajustar campañas de mitigación, guías técnicas y priorización de controles.
G	2	Sufre de sub-reporting, clasificación desigual y sesgos organizativos.
M	5	Habla el lenguaje de incidentes reales, no sólo de prácticas deseadas.
C	3	Precisión variable según calidad del sistema de notificación nacional.
T	3	Los datos suelen consolidarse con retraso (anual).
I	3	Puede depender de cambios en normativa de notificación y cultura de transparencia.
\$	3	Requiere infraestructuras de reporte y análisis nacional.

M2.2.x - Tasa de incidentes STRIDE por sector

Criterio	Puntuación	Comentario
P	4	Permite prever sectores bajo mayor presión y ajustar esfuerzos regulatorios.
R	5	Fundamental para política sectorial y priorización de ayudas.
A	4	Ayuda a diseñar programas sectoriales específicos.
G	2	Misma fragilidad de datos que M2.1.x, con plus de variabilidad sectorial.
M	4	Muy significativa para comparar sectores, con cautela.
C	3	Depende de censo fiable de organizaciones por sector.
T	3	Actualización anual razonable.
I	3	Afectada por cultura de reporte de cada sector.
\$	3	Similar coste a M2.1.x.

M2.3.x - Tendencia % anual de incidentes STRIDE

Criterio	Puntuación	Comentario
P	5	El cambio en el tiempo es el mejor indicador de si la estrategia funciona.
R	5	Directamente alineado con objetivos de reducción de incidentes.
A	4	Permite reorientar planes si la tendencia no mejora.
G	2	La genuinidad sufre cuando cambios de clasificación afectan la serie.
M	4	La dirección del cambio (mejora/empeora) es muy comprensible.
C	3	El ruido en los datos complica la precisión.
T	3	Siempre habrá retraso, pero es aceptable.
I	3	Parcialmente dependiente de cambios en reporting y criterios.
\$	4	Cálculo barato si ya se dispone de M2.1.x.

3. Métricas del Indicador 3 – Simulación de ataques

M3.1 – % de OSE que realizan ≥ 1 ejercicio de simulación al año

Criterio	Puntuación	Comentario
P	4	Fuerte indicador de preparación, aunque no de calidad del ejercicio.
R	4	Relevante para medir madurez operacional (G1, G3).
A	4	Permite fijar mínimos regulatorios (“al menos un ejercicio anual”).
G	3	Riesgo de ejercicios “de fachada” sólo para cumplir expediente.
M	4	Señal clara: “practicamos o no practicamos”.
C	3	Depende de definiciones y de auto-reporte.
T	4	Datos anuales disponibles con relativa facilidad.
I	3	Influido por incentivos normativos y reputacionales.
\$	4	Barato de recabar via cuestionario.

M3.2 – N° medio de sistemas/servicios críticos cubiertos por ejercicio

Criterio	Puntuación	Comentario
P	4	Cuanto más se cubre, más probable detectar fallos estructurales.
R	4	Relevante para valorar profundidad de la práctica.
A	3	Sirve para guiar recomendaciones, aunque su traducción en política es menos directa.
G	3	Requiere definiciones claras de “sistema crítico” y “cobertura”.
M	4	Diferencia ejercicios simbólicos de ejercicios sustantivos.
C	3	Datos auto-reportados con posible inexactitud.
T	3	Puede acumularse con cierto retraso.
I	3	Sensible a prácticas de clasificación internas.
\$	3	Algo más caro de obtener que M3.1.

M3.3 – % de ejercicios con planes de acción implementados

Criterio	Puntuación	Comentario
P	4	Mejora la capacidad de que los ejercicios transformen la realidad.
R	5	Directamente alineada con G3 (resiliencia) y G4 (eficiencia).
A	5	La métrica más accionable: ejercitar + mejorar.
G	3	Puede haber planes aprobados pero no efectivamente ejecutados.
M	5	Mide si se aprende de las simulaciones o sólo se archivan informes.
C	3	Precisión depende de seguimiento y evidencias.
T	3	Suelen necesitar ciclos largos para consolidarse.
I	3	Depende de cultura de mejora continua.
\$	3	Requiere algo más de trabajo de seguimiento.

4. Métricas del Indicador 4 – Resiliencia (MTTR crítico)

M4.1 – MTTR crítico (tiempo medio de recuperación tras incidentes muy graves)

Criterio	Puntuación	Comentario
P	5	Alto predictor de daño real y capacidad de recuperación futura.
R	5	Directamente alineado con continuidad de servicios esenciales (G1, G3).
A	4	Permite fijar objetivos de mejora y SLAs de país/sector.
G	3	Depende de registro honesto y completo de incidentes.
M	5	Una cifra que hasta el más lego entiende: cuánto tardamos en levantarnos.
C	3	Difícil de medir con precisión homogénea entre sectores.
T	3	Datos consolidados con retraso; cada incidente es un dato.
I	3	Influidos por decisiones políticas de comunicación.
\$	2	Costosa: requiere sistemas de medición y coordinación alta.

M4.2 – Distribución del MTTR por sector

Criterio	Puntuación	Comentario
P	4	Predice sectores particularmente vulnerables.
R	5	Clave para priorizar inversiones y regulaciones sectoriales.
A	4	Permite diseñar programas sectoriales específicos.
G	3	Igual fragilidad de datos que M4.1, amplificada sectorialmente.
M	4	Muy significativa para comparativas.
C	3	Precisión moderada.
T	3	Ritmo anual.
I	3	Depende de prácticas de reporte por sector.
\$	2	Coste similar a M4.1.

M4.3 – Correlación MTTR vs. madurez de Threat Modeling

Criterio	Puntuación	Comentario
P	5	Si se ve correlación, legitima las inversiones en madurez; si no, hay preguntas incómodas.
R	5	Central para G2 (madurez) y G3 (resiliencia).
A	4	Permite reorientar políticas hacia lo que realmente reduce MTTR.
G	3	Depende de calidad de las dos familias de datos.
M	4	Resultado muy significativo para narrativa política y de negocio.
C	3	Requiere análisis estadístico serio.
T	2	Necesita varios años de datos consistentes.
I	3	Influidos por factores externos (recursos, contexto sectorial).
\$	3	Coste analítico adicional, pero asumible.

5. Métricas del Indicador 5 – Integración en riesgo y ROI

M5.1 – % de entidades que integran Threat Modeling en metodología de riesgo

Criterio	Puntuación	Comentario
P	4	Sugiere mayor coherencia entre visión técnica y gestión corporativa.
R	5	Alineada con NIS2 y marcos de gestión basada en riesgo (G2, G4).
A	4	Permite promover guías y requerimientos formales.
G	3	Riesgo de integración nominal sin efecto práctico.
M	4	Mide si los modelos salen del departamento técnico y llegan a gestión.
C	3	Precisión limitada por la subjetividad de “integrar”.
T	4	Actualizable con ciclos de encuesta.
I	3	Afectada por cultura de cumplimiento formalista.
\$	4	Recogida barata vía encuesta.

M5.2 – % de entidades que vinculan escenarios PASTA con continuidad y ejercicios

Criterio	Puntuación	Comentario
P	4	Conecta análisis preventivo con preparación reactiva.
R	5	Muy relevante para resiliencia (G3).
A	4	Permite exigir esa vinculación en guías de cibercrisis.
G	3	Necesita criterio claro de qué se considera “vinculación”.
M	4	Diferencia ejercicios genéricos de los basados en amenazas reales.
C	3	Depende de auto-reportes.
T	3	Ciclos de ejercicio son normalmente anuales.
I	3	Influido por madurez organizativa.
\$	4	Barato de medir.

M5.3 – % de entidades que usan Threat Modeling para justificar inversiones/ROI

Criterio	Puntuación	Comentario
P	4	Indica probabilidad de decisiones de inversión más racionales.
R	5	Directamente vinculado a G4 (eficiencia económica).
A	5	Métrica altamente accionable para políticas y programas de apoyo.
G	3	Puede haber “uso cosmético” de modelos en presentaciones.
M	4	Muy significativa en conversaciones con Ministerio de Hacienda y equivalentes.
C	3	Difícil de verificar externamente.
T	3	Evolución algo más lenta.
I	3	Depende de madurez financiera y de gestión.
\$	4	Recogida barata vía encuesta.

6. Selección y priorización

Las métricas con mayor suma PRAGMATIC (por ejemplo, M1.3, M2.3.x, M3.3, M4.1, M5.3) deberían priorizarse como “núcleo duro” del cuadro de mando nacional o sectorial, manteniendo las demás como complementarias.

El uso disciplinado de esta matriz evita caer en el fetichismo numérico: no todas las métricas se merecen el esfuerzo de ser medidas, y esta tabla ayuda a separar el grano de la paja.